INFORME TÉCNICO DE AUDITORÍA

Auditoría de Ciberseguridad

GlucoLume

Plataforma web de seguimiento glucémico y oximetría con dispositivo IoT

Marco de referencia:

- OWASP Top 10 (2021) – riesgos de aplicaciones web
- OWASP API Security Top 10 (2019) – riesgos de APIs REST
- ISO/IEC 27001:2022 – controles del Anexo A y SGSI
- NIST Cybersecurity Framework 2.0 – funciones GV, ID, PR, DE, RS, RC

Alcance:

Repositorio completo del proyecto (backend FastAPI, frontend React/Vite, base de datos SQL Server, despliegue Docker, puente de adquisición serie y firmware Arduino), revisado sobre el código fuente, la configuración de despliegue, los scripts de base de datos y respaldos, y la documentación interna de seguridad del proyecto.

Metodología:

Auditoría basada en evidencia: revisión de código (estática), revisión de configuración (Docker, Nginx, Caddy, env), revisión de scripts SQL y de respaldos, y contraste con las autodeclaraciones documentadas del proyecto. Cada hallazgo se apoya en archivos y líneas concretas del repositorio.

Fecha de auditoría: 21/10/2026

Versión del informe: 1.0

Proyecto de titulación – Licenciatura en Sistemas de Información

Autor/a: _____ Director/a: _____

Este informe es una auditoría técnica interna con fines académicos. No constituye una certificación ISO/IEC 27001 ni una auditoría externa oficial.

Índice

1. Resumen ejecutivo **3**

2. Alcance y metodología **3**

2.1 Marco normativo y de buenas prácticas 3

2.2 Actividades realizadas 3

3. Arquitectura del sistema evaluada **4**

4. Controles de seguridad presentes (verificados con evidencia) **4**

5. Controles ausentes o pendientes **7**

6. Hallazgos y tabla consolidada de riesgos **8**

7. Recomendaciones priorizadas **11**

P1-1 · Copia offsite de respaldos y clave (cierra H-01) 11

P1-2 · Aplicar los permisos de base de datos (cierra H-02) 11

P1-3 · Aprobar la política de retención y fijar valores (cierra H-04) 11

P1-4 · Forzar API_ENV explícito en producción (cierra H-07) 11

P2-1 · Declarar y mitigar el riesgo del canal Bluetooth (cierra H-05) 11

P2-2 · Rate limiting compartido (cierra H-06, H-11) 12

P2-3 · Procedimiento de rotación de secretos (cierra H-08) 12

P2-4 · Cifrado en reposo (mitiga H-03) 12

P2-5 · Auditoría de errores 500 inesperados (cierra parte de H-15 y control ausente) 12

P3 · Mejoras de baja severidad (cierran H-10, H-12, H-13, H-14, H-16, H-17) 12

8. Evaluación por dominio de control **14**

8.1 Mapeo OWASP Top 10 (2021) 14

8.2 Mapeo NIST CSF 2.0 e ISO 27001 (Anexo A) 14

9. Conclusión ejecutiva **15**

10. Referencias y evidencia **15**

1. Resumen ejecutivo

GlucoLume es una plataforma web de salud (seguimiento de glucemia estimada, frecuencia cardíaca y SpO2) compuesta por una API FastAPI (Python), una base de datos SQL Server, un frontend React SPA servido por Nginx, un puente de adquisición en Windows que recibe lecturas de un dispositivo Arduino por USB/Bluetooth, y un despliegue contenedor con proxy HTTPS (Caddy). Por tratarse de datos personales de salud, el sistema maneja información de categoría especial, sujeta a la Ley 25.326 de Protección de los Datos Personales de Argentina.

La auditoría encontró una postura de seguridad inusualmente sólida para un proyecto de titulación: el backend usa hashing Argon2id, JWT con validación de sesión en base de datos (revocación real), refresh tokens rotados con detección de reutilización (robo), bloqueo de cuenta por intentos fallidos implementado de forma atómica, MFA TOTP con secreto cifrado (Fernet) y rotación de claves, OAuth2/OIDC con state, nonce y PKCE, validación estricta de entrada con Pydantic (extra="forbid"), autorización centralizada por permisos que mitiga IDOR, auditoría de solo-inserción con minimización de datos personales, cabeceras de seguridad y CSP estricta sin 'unsafe-inline', contenedores multi-stage sin root con imágenes fijadas por digest, dependencias bloqueadas con hashes, respaldos cifrados AES-256 con verificación de restauración, y una suite de pruebas que fija como invariante que ningún endpoint privado carece de autenticación.

No se identificó ningún hallazgo de riesgo ALTO en el código de aplicación: no hay SQL dinámico con riesgo de inyección, no hay secretos hardcodeados ni versionados en Git, y los controles de autenticación y autorización están implementados de manera sistemática y probada.

Los riesgos residuales se concentran en la operación y en decisiones pendientes: (1) los respaldos y su clave de cifrado residen en el mismo equipo físico, sin copia offsite verificada — único hallazgo de riesgo ALTO; (2) el esquema de permisos de base de datos de mínimo privilegio está diseñado pero no aplicado en la instancia real; (3) los datos en reposo no están cifrados (SQL Server Express no admite TDE); (4) los plazos de retención de auditoría y datos personales aún no fueron aprobados legalmente; (5) el canal Bluetooth del dispositivo transmite datos de salud sin cifrado ni autenticación; y (6) el rate limiting en memoria no escala con múltiples réplicas. Cada uno se detalla y recomienda en las secciones 6 y 7.

Valoración global de madurez: NIVEL ALTO en protección técnica (Protect), MEDIO-ALTO en detección y respuesta (Detect/Respond), y MEDIO en gobernanza (Govern: políticas de retención y procedimientos operativos pendientes). Con la ejecución del plan de remediación priorizado de la sección 7, el sistema queda en condiciones de operar con un perfil de riesgo aceptable para datos de salud.

2. Alcance y metodología

2.1 Marco normativo y de buenas prácticas

La evaluación se realizó contra tres marcos reconocidos, usados de forma complementaria:
• OWASP Top 10 (2021) y OWASP API Security Top 10: clasificación de los riesgos de la aplicación web y de la API REST.
• ISO/IEC 27001:2022 (Anexo A, controles A.5 y A.8): verificación de controles organizacionales y técnicos de un SGSI.
• NIST Cybersecurity Framework 2.0: organización de los controles por las funciones GOVERN, IDENTIFY, PROTECT, DETECT, RESPOND y RECOVER.

2.2 Actividades realizadas

- Revisión estática del código del backend (app/core, app/api, app/services, app/db, app/schemas) y de sus tests de seguridad (test_security_config.py, test_security_hardening.py).
- Revisión del frontend (manejo de tokens, XSS, guardas de ruta, dependencias de package.json/package-lock.json).
- Revisión de la infraestructura: Dockerfiles, compose.yaml/prod.yaml, plantilla Nginx, Caddyfile, permisos de base de datos (GlucoLume_permisos.sql), scripts de respaldo y restauración (PowerShell).

- Revisión del puente de adquisición (acquisition/bridge) y del firmware Arduino (GlucoLume_MAX30100).
- Verificación de gestión de secretos (.gitignore vs. archivos .env reales, confirmado con git check-ignore y git ls-files).
- Contraste con la documentación interna del proyecto (docs/SEGURIDAD.md, docs/PRIVACIDAD_Y_RETENCION.md, docs/PENDIENTES.md, evidencia de escaneo de CVEs) y con las pruebas automatizadas existentes.

Clasificación de riesgo adoptada: ALTO (impacto mayor sobre confidencialidad/integridad/disponibilidad con probabilidad realista en el despliegue actual), MEDIO (impacto acotado o con mitigaciones parciales vigentes), BAJO (riesgo residual menor o de mejora continua). Cada hallazgo incluye evidencia (archivo:línea) verificable en el repositorio.

3. Arquitectura del sistema evaluada

Componentes identificados en el repositorio y su relevancia para la seguridad:

Componente	Tecnología	Rol y superficie de exposición
API backend	Python 3.14, FastAPI, SQLAlchemy 2, pyodbc	API REST /api/v1. Autenticación JWT Bearer + sesión en BD. Solo alcanzable desde la red interna 'edge' (Nginx); no publica puertos en producción.
Frontend SPA	React 19 + Vite 6, servido por Nginx unprivileged	Único componente publicado (puerto 80/8080). Proxy /api hacia el backend; CSP estricta y cabeceras de seguridad.
Base de datos	SQL Server 2022 Express (nativo) / contenedor opcional	Red interna 'data'. Conexión con Encrypt=yes y validación de certificado del servidor en producción.
Proxy HTTPS	Caddy 2.11 (perfil 'https')	TLS automático Let's Encrypt, HSTS, redirección HTTP→HTTPS.
Puente de adquisición	Python en Windows (acquisition/bridge)	Lee el dispositivo por USB/Bluetooth y envía lecturas a la API con token X-Bridge-Token; fuerza HTTPS fuera de localhost.
Dispositivo IoT	Arduino + MAX30100 (firmware .ino), HC-05/HC-06	Emite BPM, SpO2, glucosa estimada y PPG por serie/Bluetooth sin cifrado.
Jobs de conservación	Servicio 'lifecycle' (compose)	Anonimiza y elimina cuentas vencidas con cuenta de base separada (única con permisos de depuración).

Separación de redes: la red 'edge' conecta frontend↔backend↔proxy; la red 'data' conecta backend↔SQL Server. El frontend no ve la base y el backend no publica puertos al exterior. Los contenedores corren read-only, con cap_drop: ALL, no-new-privileges, límites de CPU/memoria y logs acotados.

4. Controles de seguridad presentes (verificados con evidencia)

Control	Estado	Evidencia principal en el repositorio
Hashing de contraseñas	Argon2id (pwdlib), con rehash automático y hash dummy anti-enumeración de tiempos	backend/app/core/security.py:19-44,136-143

Control	Estado	Evidencia principal en el repositorio
Política de contraseñas	Mín. 8/máx. 128, complejidad, lista de contraseñas comunes, rechazo de contraseñas con el nombre/usuario	security.py:54-129; commonPasswords.txt
JWT robusto	Algoritmo restringido, iss/aud/typ verificados, expiración 30 min, sesión revalidada en BD (revocación real), tokens de propósito único	security.py:25-35,169-221; api/deps.py:30-43
Refresh tokens	Opacos CSPRNG 48 bytes almacenados como SHA-256, rotación atómica, detección de reutilización (robo) con revocación total de sesiones	core/security.py:149-156; services/auth.py:913-937
Bloqueo por intentos	3 intentos → bloqueo 15 min, UPDATE condicionado atómico, Retry-After, evento de auditoría y aviso por correo	services/auth.py:414-476; tests/test_login_lockout.py
MFA TOTP	Secreto cifrado con Fernet/MultiFernet y rotación de claves, verificación con compare_digest, rechazo de reuso de código, códigos de recuperación SHA-256, MFA obligatorio para cuentas administrativas de plataforma	core/security.py:278-348; api/deps.py:64-71
Google OAuth2/OIDC	Authorization Code con state + nonce + PKCE S256, validación completa del id_token (firma, issuer, audience, exp, nonce), vinculación solo con email_verified	integrations/google/oauth.py:1-51; main.py:36-38,71-78
Inyección SQL (A03)	Sin SQL dinámico con f-strings/format en app/; ORM SQLAlchemy tipado y text() solo con SQL estático; LIKE con autoescape	grep sobre app/; services/auditQuery.py; authAccess.py:56-66
Control de acceso y IDOR (A01)	RBAC por capas, punto único requireMembership por recurso, permisos granulares, respuesta 404 (no 403) para recursos ajenos anti-enumeración	services/institution.py:263-292; measurement.py:702; tests/test_auth_access*.py
Validación de entrada (A03/A10)	Pydantic estricto extra="forbid" en TODOS los esquemas (invariante probada), límites de tamaño, SecretStr para contraseñas	tests/test_security_hardening.py:309-360
Rate limiting	16 límites por IP en endpoints públicos con 429+Retry-After; IP real no falsificable (Nginx fija X-Forwarded-For; uvicorn FORWARDED_ALLOW_IPS acotado); límite adicional en Nginx (limit_req)	api/rateLimit.py:23-87; docker/nginx/default.conf.template:33,86-88

Control	Estado	Evidencia principal en el repositorio
Cabeceras de seguridad	Backend: nosniff, Cache-Control no-store en datos de salud, CSP default-src 'none', HSTS condicional. Nginx: CSP estricta sin unsafe-inline, X-Frame-Options DENY, Referrer-Policy, Permissions-Policy, server_tokens off	api/securityHeaders.py:21-45; default.conf.template:41-51
Auditoría y logging (A09)	Eventos de auditoría de solo-insersión (DENY UPDATE/DELETE a la API), minimización de PII (identificadores como HMAC, user-agent resumido), retención de IP 90 días, monitor de ráfagas por origen con alerta por correo	services/audit.py:200-285; GlucoLume_permisos.sql:63-64
Manejo de errores	422 sin devolver el valor recibido, códigos estables sin PII, 500 genérico sin detalles internos, causa técnica solo en log	api/errors.py:206-226; auth.py:283-287
Cifrado en tránsito	HTTPS con Caddy (Let's Encrypt) y HSTS; conexión a SQL Server Encrypt=yes/strict con validación de certificado en producción; SMTP con STARTTLS CERT_REQUIRED TLS≥1.2	compose.prod.yaml:44-65; db/session.py:41-49; tests/test_security_config.py:49-69
Gestión de secretos	SecretStr obligatorios sin defaults inseguros, mínimo 32 caracteres, anti-reutilización de secretos entre variables, .env excluido de Git (verificado), errores sin filtrar valores	core/config.py:28-31,153-171,246-275; .gitignore:100-102
Respaldos (A.8.13 / RC)	BACKUP CHECKSUM + RESTORE VERIFYONLY, cifrado GnuPG AES-256 con verificación round-trip, clave CSPRNG protegida con DPAPI, retención 35 días + 12 meses, restauración de prueba mensual en instancia descartable	database/respaldos/*.ps1; docs/SEGURIDAD.md:120
Dependencias y CVEs (A06)	pip-compile con --generate-hashes e instalación --require-hashes; npm versiones exactas con lockfile; imágenes Docker fijadas por digest con apk/apt upgrade; evidencia de escaneo con 0 críticas y 1 alta residual rastreada (zlib)	requirements.txt; package.json; Dockerfiles; docs/DESPLIEGUE.md:146-148
Hardening de contenedores	Multi-stage, usuario no-root dedicado, read_only, cap_drop ALL, no-new-privileges, healthchecks, límites de recursos, OpenAPI/docs ocultos en producción, uvicorn --no-server-header	compose.yaml:27-31,54-81; backend/Dockerfile:51-57; frontend/Dockerfile:50
Privacidad y retención	Anonimización y eliminación de cuentas con período de gracia, servicio lifecycle dedicado, política documentada de minimización	docs/PRIVACIDAD_Y_RETENCION.md; app/jobs/accountLifecycle.py

Control	Estado	Evidencia principal en el repositorio
Pruebas de seguridad	Invariantes automatizados: todo endpoint privado exige sesión (allowlist de 24 públicas), ninguna respuesta expone hashes/tokens, límites por IP, headers, IP no falsificable. ~51 suites frontend + ~100 backend	tests/test_security_hardening.py:253-351; frontend/src/**/*.test.*

5. Controles ausentes o pendientes

Control esperado	Estado	Referencia de marco
Copia offsite/geográfica de respaldos y de la clave de cifrado	Ausente (paso manual declarado pendiente)	ISO 27001 A.5.14, A.8.13; NIST CSF RC.RE
Aplicación de permisos de mínimo privilegio en la instancia real de BD	Diseñado (script completo) pero no aplicado	ISO 27001 A.8.2, A.8.3; OWASP API1
Cifrado de datos en reposo (TDE) o cifrado de columnas	Preparado en script; no aplicable en SQL Server Express; mitigado con backups cifrados y conexión cifrada	ISO 27001 A.8.24; OWASP A02
Política de retención aprobada legalmente (auditoría y datos personales)	Pendiente de aprobación legal; defaults actuales: retención indefinida	ISO 27001 A.5.34; Ley 25.326
Cifrado/autenticidad del canal Bluetooth del dispositivo	Ausente (riesgo no declarado como aceptado en docs/SEGURIDAD.md)	ISO 27001 A.8.20; OWASP A08
Rate limiting compartido entre réplicas (Redis) y WAF	Pendiente declarado (monolito de una réplica; límites en memoria)	OWASP A04 / API4; NIST CSF PR.DS-5
Procedimiento documentado de rotación de secretos	Pendiente (GL-20 autodeclarado); capacidad técnica existe (BRIDGE_PREVIOUS_TOKEN, MFA_PREVIOUS_ENCRYPTION_KEYS)	ISO 27001 A.8.24; NIST CSF PR.P
Gestión de eventos 500 inesperados en auditoría	Ausente (500 genérico de Starlette sin evento de auditoría unificado)	ISO 27001 A.8.16
Gestor de errores global (ErrorBoundary) en la SPA	Ausente	OWASP A05 (disponibilidad/UX)
Monitoreo/alertado externo (SIEM, uptime, alertas de restauración)	Ausente (logs locales con retención; sin centralización)	NIST CSF DE.CM; ISO 27001 A.8.16

6. Hallazgos y tabla consolidada de riesgos

Diecisiete hallazgos identificados. Ninguno corresponde a vulnerabilidades de inyección (A03) ni a fallos de autenticación (A07) en el código: esos dominios resultaron sólidos. Los riesgos se concentran en configuración, operación y canal físico.

ID	Hallazgo	Riesgo	OWASP	ISO 27001 / NIST CSF	Impacto principal
H-01	Respaldos cifrados y su clave DPAPI residen en el mismo equipo/disco; no existe copia offsite verificada (regla 3-2-1 incompleta).	ALTO	A04 / API2	A.8.13 · RC	Pérdida total de los datos de salud ante falla de disco, incendio o ransomware sobre un único equipo.
H-02	El esquema de permisos de BD de mínimo privilegio (roles API/retención, DENY sobre Auditoría) está diseñado pero NO aplicado en la instancia real.	MEDIO	A01 / API1	A.8.2 · PR	Una credencial comprometida de la API tendría permisos excesivos, incluida escritura sobre tablas sensibles.
H-03	Datos en reposo sin cifrar: la instancia real es SQL Server Express (sin TDE ni backups cifrados nativos).	MEDIO	A02	A.8.24 · PR	Acceso directo al archivo .mdf/.ldf expone datos de salud; mitigado parcialmente con backups AES-256 y conexión cifrada.
H-04	Retención por defecto indefinida de eventos de auditoría y datos personales de personal (plazos legales aún no aprobados).	MEDIO	A02 (privacidad)	A.5.34 · GV	Incumplimiento potencial de la Ley 25.326 (plazo de conservación de datos de salud) al operar en producción.
H-05	El firmware transmite BPM/SpO2/glucosa/PPG por Bluetooth HC-05/HC-06 sin cifrado ni autenticidad, con emparejamiento de PIN débil (1234/0000). Riesgo no declarado como aceptado.	MEDIO	A08 / A02	A.8.20 · PR	Escucha e inyección de lecturas por un atacante cercano al dispositivo; atenuado por la validación estricta del backend.
H-06	Rate limiting en memoria por proceso: con más de una réplica el límite por IP se multiplica por réplica.	MEDIO	A04 / API4	A.8.16 · PR	Abuso/credential stuffing más eficaz si el sistema escala a varias réplicas sin Redis.
H-07	API_ENV tiene default "development": un despliegue que olvide fijarlo activa OpenAPI/docs y TrustServerCertificate implícito (solo se advierte en log).	MEDIO	A05	A.8.9 · PR	Exposición de documentación de API y confianza TLS implícita en producción por error humano.

ID	Hallazgo	Riesgo	OWASP	ISO 27001 / NIST CSF	Impacto principal
H-08	Rotación de secretos reales pendiente de procedimiento (JWT_SECRET, SESSION_SECRET, BRIDGE_TOKEN, DB_PASSWORD en .env en texto plano).	MEDIO	A02 / A05	A.8.24 · PR	Secretos de larga vida: su filtración (p. ej. copia de seguridad del equipo) obliga a una rotación manual sin procedimiento formal.
H-09	Refresh token almacenado en Web Storage (sessionStorage/localStorage con "Recordarme"), robable por XSS o extensiones del navegador.	MEDIO	A07	A.8.2 · PR	Robo de sesión prolongada; mitigado por rotación con detección de reuso y access token de 30 min solo en memoria.
H-10	CVE alta sin parche publicada para zlib (CVE-2026-85091) en la imagen base del backend, aceptada y rastreada por el proyecto.	MEDIO-BAJO	A06	A.8.8 · ID	Superficie de ataque de la librería de compresión; sin exploit conocido en esta ruta de uso.
H-11	Sin límite de tasa por IP en endpoints autenticados (solo límites por cuenta/sesión).	BAJO	A04 / API4	A.8.16 · PR	Un token robado permite abuso sin límite por origen.
H-12	Parámetros de Argon2 no fijados explícitamente (se confía en los defaults de pwdlib).	BAJO	A02	A.8.24 · PR	Deriva silenciosa de la dureza del hashing; verify_and_update permite migración futura.
H-13	Inconsistencia menor de gestión de claves: el HMAC de identificadores de auditoría deriva su clave con SHA256(prefijo+JWT_SECRET) en lugar del patrón HKDF usado para otros propósitos.	BAJO	A02	A.8.24 · PR	Riesgo teórico de correlación de claves entre propósitos.
H-14	Tokens de enlace de un solo uso viajan brevemente por query (?token=) y quedan en los logs de acceso de Nginx de esa primera carga, aunque se borran de la barra e historial.	BAJO	A02 / A05	A.8.15 · PR	Exposición breve de enlaces de verificación/recuperación en logs locales.
H-15	Sin ErrorBoundary global en la SPA: un error de render deja la app en blanco hasta recarga.	BAJO	A05	A.8.14 · RS	Indisponibilidad parcial de cara al usuario ante errores de cliente.
H-16	BRIDGE_TOKEN: token único compartido backend↔puente y ventana de doble token válido durante rotaciones.	BAJO	A07	A.8.2 · PR	El puente no es revocable individualmente; la ventana de rotación duplica transitoriamente los emisores válidos.

ID	Hallazgo	Riesgo	OWASP	ISO 27001 / NIST CSF	Impacto principal
H-17	React 19.1.0: la CVE-2025-55182 (React2Shell) no aplica (SPA sin SSR/RSC), pero corresponde actualizar a ≥19.1.1 por higiene.	**BAJO**	A06	A.8.8 · ID	Nulo en el estado actual; preventivo.

Distribución: 1 hallazgo ALTO, 9 MEDIO, 2 MEDIO-BAJO, 5 BAJO. La ausencia de hallazgos ALTO en código de aplicación se verificó activamente: grep de SQL dinámico sin coincidencias, invariantes automatizados de autenticación sobre todos los endpoints, y verificación de que ningún secreto está versionado en Git (git check-ignore / git ls-files).

7. Recomendaciones priorizadas

Prioridad P1 (urgente, antes de puesta en producción), P2 (alto, ≤30 días), P3 (medio, ≤90 días) y P4 (mejora continua). Se incluyen ejemplos de código y configuración.

P1-1 · Copia offsite de respaldos y clave (cierra H-01)

Riesgo ALTO. Aplicar la regla 3-2-1: mantener al menos una copia de los .bak cifrados y de la frase de respaldo fuera del equipo (otro disco físico + un destino remoto). Ejemplo de paso automatizable sobre el script existente:

```
# Al final de GlucoLume_respaldo.ps1, tras la verificación exitosa del backup:
robocopy $BackupDir \\servidor-nas\glucolume-respaldos\ /MIR /XD pendiente /R:3 /W:10 /LOG+:$LogFile
# Y una copia de la clave (exportada con -Mostrar) en un cofre/gerente de contraseñas aparte.
```

Alternativa en la nube: Azure Blob (hdiis) o S3 con versión inmutable (object lock). Probar la restauración desde la copia remota con GlucoLume_prueba_restauracion.ps1 al menos trimestralmente.

P1-2 · Aplicar los permisos de base de datos (cierra H-02)

El script database/reference/GlucoLume_permisos.sql ya implementa roles de mínimo privilegio, DENY UPDATE/DELETE sobre dbo.Auditoría para la API y verificación integrada. Aplicar en la instancia real y crear también la cuenta de jobs (DB_JOBS_USER/DB_JOBS_PASSWORD) que compose.yaml ya excluye de la API:

```
sqlcmd -S localhost\GLUCOLUME -E -i "database\reference\GlucoLume_permisos.sql" CONFIRMAR
sqlcmd -S localhost\GLUCOLUME -E -i "database\reference\GlucoLume_permisos_verificar.sql"
```

P1-3 · Aprobar la política de retención y fijar valores (cierra H-04)

Los defaults AUDIT_RETENTION_MONTHS=0 y PERSONNEL_RETENTION_MONTHS=0 conservan datos indefinidamente y el propio código los marca como 'plazo legal todavía no aprobado'. Con asesoría legal, fijar valores concretos (el proyecto propone 120 meses como base técnica) y programar el job de purga:

```
# .env de producción (valores a confirmar con asesoría legal; ejemplo coherente con la política interna)
AUDIT_RETENTION_MONTHS=24
AUDIT_CONTEXT_RETENTION_DAYS=90
PERSONNEL_RETENTION_MONTHS=120
# Programar además purgeInstitutionalRetention (hoy declarado pendiente en docs/PENDIENTES.md).
```

P1-4 · Forzar API_ENV explícito en producción (cierra H-07)

Endurecer el arranque para que un despliegue sin API_ENV falle en lugar de caer en 'development':

```
# app/core/config.py – validador de modelo añadido a Settings
@model_validator(mode="after")
def _exigir_entorno(self):
    if not os.environ.get("API_ENV"):
        raise ValueError("API_ENV debe definirse explícitamente (development|production)")
    return self
# Alternativa sin código: compose.prod.yaml ya fija API_ENV=production; documentar que ES
# obligatorio desplegar SIEMPRE con compose.prod.yaml y verificar /docs cerrado.
```

P2-1 · Declarar y mitigar el riesgo del canal Bluetooth (cierra H-05)

El canal serie/Bluetooth del firmware es el único riesgo no autodeclarado por la documentación del proyecto. Dos acciones complementarias:
(a) Registrarlo explícitamente en docs/SEGURIDAD.md como riesgo aceptado del prototipo, con su justificación (distancia física, validación estricta del backend, token del puente).
(b) Añadir integridad por línea en el firmware (no confidencialidad, pero sí autenticidad frente a inyección):

```
// GlucoLume_MAX30100.ino – firma ligera por línea (clave derivada del código del dispositivo)
// payload: "BPM=72;SPO2=97;..." + ";H=" + first8(HMAC-SHA256(linea, key))
```

```
// El puente/backend rechaza líneas sin firma válida (verificación ya centralizada en el backend).
// O alternativamente: cambiar HC-06 por BLE con pairing Just Works + capa de cifrado propia.
```

P2-2 · Rate limiting compartido (cierra H-06, H-11)

Si se contempla escalar a más de una réplica, mover la ventana de límites a Redis (el proyecto ya lo prevé como decisión pendiente). Ejemplo mínimo compatible con la implementación actual:

```
# Sustituir el dict en memoria de app/api/rateLimit.py por una ventana Redis:
async def _permit(key: str, limit: int, window: int) -> bool:
    now = int(time.time()); slot = now // window
    pipe = redis.pipeline()
    pipe.incr(f"rl:{key}:{slot}"); pipe.expire(f"rl:{key}:{slot}", window * 2)
    count, _ = await pipe.execute()
    return count <= limit
# Adicional: aplicar el mismo decorador a endpoints autenticados con límites más altos (p. ej. 600/min).
```

P2-3 · Procedimiento de rotación de secretos (cierra H-08)

Documentar un procedimiento semestral de rotación con ventana de doble secreto (la capacidad ya existe para BRIDGE y MFA; falta para JWT/SESSION/DB). Para JWT sin invalidar sesiones activas, firmar con clave nueva y aceptar la anterior hasta el vencimiento de los tokens (máx. 30 min) y de los refresh (7 días):

```
# Patrón de rotación JWT compatible con el código actual (verificación con algoritmo fijo):
JWT_SECRET=<nuevo>
JWT_PREVIOUS_SECRET=<anterior>   # solo durante 7 días; eliminar después
# decode(): intentar con JWT_SECRET; si falla la firma, reintentar con JWT_PREVIOUS_SECRET.
# Rotar además: SESSION_SECRET, DB_PASSWORD (crear/alterar login) y GOOGLE_CLIENT_SECRET.
```

P2-4 · Cifrado en reposo (mitiga H-03)

Manteniendo SQL Server Express, aplicar las mitigaciones ya previstas por el proyecto: cifrado de disco BitLocker en el servidor (protege .mdf/.ldf ante robo del equipo) y mantener el cifrado AES-256 de los respaldos. Planificar la migración a una edición con TDE (Standard o contenedor 2022-CU16 del perfil 'db') cuando el sistema pase a producción formal; el script GlucoLume_cifrado_y_respaldo.sql ya prepara ese camino. La alternativa Always Encrypted fue evaluada y descartada correctamente por romper la búsqueda sobre identificadores de pacientes; conviene dejar esa decisión documentada como se hizo.

P2-5 · Auditoría de errores 500 inesperados (cierra parte de H-15 y control ausente)

```
# app/main.py – handler global que registra sin filtrar detalles al cliente
@app.exception_handler(Exception)
async def _unhandled(request: Request, exc: Exception):
    register_event(tipo="ERROR_INESPERADO", motivo=type(exc).__name__,
                   observacion=str(exc)[:1000])  # solo en auditoría, nunca en la respuesta
    return JSONResponse(status_code=500, content={"detail": "ERROR_SERVIDOR"})
```

En el frontend, añadir un ErrorBoundary de React que muestre un mensaje de disculpas y recarga:

```
// src/components/ErrorBoundary.jsx (clase con componentDidCatch -> log + UI de recuperación)
<ErrorBoundary fallback={<PantallaError />}><App /></ErrorBoundary>
```

P3 · Mejoras de baja severidad (cierran H-10, H-12, H-13, H-14, H-16, H-17)

- Argon2 con parámetros explícitos y versionados en la política (OWASP 2024: m=64 MiB, t=3, p=4): Argon2Hasher(time_cost=3, memory_cost=64*1024, parallelism=4) en core/security.py; verify_and_update ya migraría hashes antiguos.
- Unificar la derivación de claves: usar el helper HKDF derivedKey("auditoria-identificador") también para el HMAC de identificadores (audit.py:204), como ya se hace para códigos cortos (GL-17).
- Actualizar React a ≥19.1.1 con npm update y re-verificar el lockfile (higiene; la CVE no aplica a esta SPA).
- Migrar los enlaces de verificación/recuperación al fragmento (#token=) como ya se hizo para Google (#code=), evitando que queden en logs de acceso de Nginx; o registrar en nginx un log_format que

enmascare la query de esas rutas.

- Tabla de puentes con token por dispositivo (el propio proyecto lo tiene registrado como GL-11) para revocar un puente sin afectar a los demás; documentar la ventana de rotación BRIDGE_PREVIOUS_TOKEN con plazo máximo explícito.
- Volver a construir la imagen del backend cuando Debian publique el parche de zlib (CVE-2026-85091) y actualizar la evidencia de escaneo; mantener la práctica actual de digest pinning + escaneo documentado.
- Cambiar el PIN de emparejamiento Bluetooth (1234/0000) por uno aleatorio por unidad, aunque el enlace siga sin cifrar.

8. Evaluación por dominio de control

8.1 Mapeo OWASP Top 10 (2021)

Categoría OWASP	Evaluación	Fundamento
A01 – Broken Access Control	Sólido	Punto único de autorización por recurso; IDOR mitigado y probado; anti-enumeración 404; registro público no puede crear cuentas de plataforma.
A02 – Cryptographic Failures	Sólido con reservas	Argon2id, Fernet para MFA, SHA-256 para refresh, TLS en tránsito y en BD; reservas: datos en reposo sin cifrar (H-03) y rotación de secretos (H-08).
A03 – Injection	Sólido	Sin SQL dinámico; ORM tipado y parámetros vinculados; LIKE con autoescape; validación Pydantic estricta.
A04 – Design	Adecuado con reservas	Rate limiting por IP con IP no falsificable y lockouts atómicos; reservas: en memoria (H-06) y sin límite en autenticados (H-11).
A05 – Security Misconfiguration	Adecuado con reservas	Docs ocultos en producción, headers dobles, contenedores endurecidos; reservas: API_ENV default (H-07).
A06 – Vulnerable & Outdated Components	Sólido	Locks con hashes, versiones exactas, digest pinning, escaneo de CVEs documentado; reserva: zlib residual (H-10).
A07 – Identification & Authentication	Sólido	JWT con sesión revocable, refresh rotado con detección de robo, lockout, MFA TOTP cifrado, OIDC con PKCE/nonce; reservas: almacenamiento del refresh (H-09).
A08 – Software & Data Integrity	Reserva principal	Cadena de suministro de dependencias protegida; canal Bluetooth del dispositivo sin integridad (H-05).
A09 – Logging & Monitoring	Sólido con reserva menor	Auditoría rica minimizada con alertas internas; reserva: 500 inesperados sin evento (sección 5).
A10 – SSRF	No aplica relevante	No hay fetch de URLs proporcionadas por el usuario; los HTTP clients apuntan a endpoints fijos (Google, SMTP).

8.2 Mapeo NIST CSF 2.0 e ISO 27001 (Anexo A)

Función NIST CSF	Madurez	Controles ISO 27001 evidenciados / brechas
GOVERN (GV)	MEDIO	Política de privacidad documentada y honestamente etiquetada; brecha: retención sin aprobación legal (A.5.34), procedimientos operativos de rotación de secretos (A.8.24).
IDENTIFY (ID)	MEDIO-ALTO	Inventario de componentes y línea base de CVEs documentada (A.5.9, A.8.8); brecha: riesgo del canal Bluetooth no registrado en el registro de riesgos (A.8.20).
PROTECT (PR)	ALTO	A.8.2/A.8.3 (RBAC + diseño de permisos), A.8.24 (criptografía aplicada), A.8.25/A.8.26 (hardening de contenedores), A.8.28 (seguridad en desarrollo con invariantes probadas); brechas: permisos no aplicados, reposo sin cifrar, canal IoT.

Función NIST CSF	Madurez	Controles ISO 27001 evidenciados / brechas
DETECT (DE)	ALTO	A.8.15/A.8.16: auditoría de solo-insersión, monitor de ráfagas por origen con alerta por correo, healthchecks; brecha: sin centralización externa de logs.
RESPOND (RS)	MEDIO-ALTO	Revocación de sesiones por robo de refresh, lockouts, anonimización automática de cuentas; brecha: manejo de 500 inesperados.
RECOVER (RC)	MEDIO	A.8.13: respaldos diarios verificados + restauración de prueba mensual; brecha crítica: sin copia offsite (H-01).

9. Conclusión ejecutiva

GlucoLume presenta, a la fecha de esta auditoría, una madurez de seguridad técnica superior a la esperable en un proyecto de titulación. La revisión evidenció que los controles críticos no son aspiracionales sino implementados y probados: autenticación con revocación real de sesiones y detección de robo de tokens, autorización centralizada que elimina sistemáticamente el acceso horizontal indebido (IDOR), entrada estrictamente validada sin riesgo de inyección, criptografía actual (Argon2id, Fernet, HKDF, SHA-256) con claves gestionadas como secretos obligatorios, auditoría minimizada de solo-insersión, cadena de suministro de dependencias bloqueada y auditada por escáner, y respaldos verificados con restauración periódica de prueba. Destaca además una práctica de gobernanza poco frecuente: el proyecto autodeclara sus pendientes de seguridad etiquetándolos con evidencia ([PRUEBA]/[CÓDIGO]/[NO VERIFICADO]), lo que facilitó esta auditoría y habla bien de la trazabilidad del desarrollo.

El perfil de riesgo resultante es BAJO-MEDIO para la aplicación y MEDIO-ALTO para la operación. El único hallazgo de riesgo ALTO (respaldos y su clave en un único equipo físico) es de fácil cierre con una copia offsite automatizada, y los riesgos medios son mayormente decisiones de despliegue ya previstas por el propio proyecto (aplicar los permisos de base, aprobar los plazos de retención, escalar el rate limiting, rotar secretos) o inherentes al hardware del prototipo (canal Bluetooth), que se mitigan registrando el riesgo y añadiendo integridad por línea.

Se recomienda al jurado valorar que la totalidad de los hallazgos cuenta con evidencia verificable en el repositorio y con un plan de remediación concreto y priorizado (sección 7). Ejecutadas las acciones P1 (copia offsite, permisos de base de datos, política de retención aprobada y entorno forzado), el sistema queda en condiciones de operar con datos personales de salud bajo un marco de cumplimiento defendible frente a la Ley 25.326 y alineado con los controles del Anexo A de ISO/IEC 27001:2022 y las funciones del NIST CSF 2.0. La auditoría concluye que GlucoLume demuestra competencia profesional en ingeniería segura de software, y que su principal oportunidad de mejora no es tecnológica sino de gobierno operativo.

10. Referencias y evidencia

- OWASP Foundation, OWASP Top 10:2021 – The Ten Most Critical Web Application Security Risks.
- OWASP Foundation, API Security Top 10 (2019).
- ISO/IEC 27001:2022 – Information security, cybersecurity and privacy protection – Annex A (A.5, A.8).
- NIST, Cybersecurity Framework 2.0 (GV, ID, PR, DE, RS, RC), abril 2024.
- OWASP Password Storage Cheat Sheet (Argon2id: m≥64 MiB, t=3, p=4) y OWASP Authentication Cheat Sheet.
- Ley 25.326 de Protección de los Datos Personales (Argentina), arts. 7 bis y 10 (datos sensibles de salud).
- Repositorio auditado: GlucoLume (backend/, frontend/, docker/, database/, acquisition/, firmware/, docs/). Evidencias citadas en el cuerpo del informe con formato archivo:línea. Escaneo de CVEs: docs/evidencias/CVE_LINEA_BASE_2026-10-10.md y docs/DESPLIEGUE.md.

Nota: los valores de secretos personales no se transcriben en este informe; se documentan únicamente su existencia, formato y protección. Los nombres de variables y rutas de archivos se conservan para permitir la trazabilidad de cada hallazgo.